codigo.py
PY 52.46KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Found 12 web pages

Este arquivo é um malware. Trata-se de um script de implantação automatizada de worm de mineração/SSH (classificado como worm de botnet), cujo comportamento central é: **utilizar senhas fracas conhecidas para invadir outros servidores, implantar backdoors, transformar hosts comprometidos em "zumbis" para varredura e propagação contínua, e reportar informações ao servidor de controle do atacante.**

A seguir, a análise passo a passo:

1. Credenciais de ataque codificadas (evidência chave de comportamento malicioso)

O arquivo inclui explicitamente `TARGET_SERVER_PASSWORDS = "LeitboGi0ro,123@@@"`. Essas duas senhas são senhas padrão bem conhecidas deixadas por scripts de reinstalação "one-click" (como o script DD do LeitboGi0ro). O script tenta ativamente fazer login em outros servidores com essas senhas e, após o sucesso, implanta o payload . Usuários normais não codificam um conjunto de senhas padrão de terceiros em seus scripts para "tentar a sorte" em servidores de outras pessoas. [16] [23]

2. Cadeia completa de intrusão e propagação

O código contém um `monitor_script.py` que executa continuamente as seguintes operações:

- Lê os endereços IP que foram escaneados com sucesso pelo masscan e que possuem SSH aberto (`22,5522`).
- Usa `paramiko` para tentar login SSH com as senhas fracas acima mencionadas.
- Após o login ser bem-sucedido, faz upload do próprio arquivo `bendi.py` (ou seja, este script) para o diretório `/tmp` do host alvo e executa.
- Esse processo se repete, formando propagação em worm . [16] [23]

3. Controle remoto e reporte (infraestrutura C2)

O script se comunica com o servidor controlado pelo atacante `sou.pp.ua` :

- `check_ip.php` : verifica se o alvo já foi comprometido (evitando repetição).
- `add_ip.php` : registra o host recém-comprometido com sucesso no banco de dados do atacante.
- Envia notificações via Telegram Bot, incluindo Token e Chat ID (completos no arquivo), reportando os resultados da intrusão em tempo real ao atacante . [16]

4. Instalação de ferramentas de lucratividade e controle

Durante o processo de implantação, o script também executa:

- Instalação forçada do **Komari Agent**: embora se apresente como ferramenta de "monitoramento", o próprio documento de segurança aponta que ele possui capacidade de execução remota de comandos e é comumente abusado como canal C2 (Command and Control) .
- Instalação do **TraffMonetizer**: usado para vender a largura de banda da máquina comprometida e obter lucro . [5] [9]

Conclusão

O propósito deste arquivo não é ferramenta de operação e manutenção ou segurança, mas sim um **worm automatizado de invasão e mineração**. Ele usa senhas fracas padrão para se propagar horizontalmente, instala agentes de controle remoto e monetiza largura de banda, e reporta ativamente ao servidor do atacante. Seu comportamento é completamente consistente com o incidente público de worm "LeitboGi0ro default password" . [16] [20]

26 web pages

Qual é a categoria principal deste malware?

A categoria principal deste malware é **worm de botnet** (botnet worm), mais especificamente um **worm de propagação SSH com capacidades de monetização e C2**.

As subcategorias que ele abrange:

1. **Worm de propagação por SSH** — usa credenciais fracas codificadas (`LeitboGi0ro` , `123@@@`) para fazer login em servidores de terceiros e se auto-replicar (`bendi.py` → `/tmp` → execução).
2. **Botnet / C2** — registra hosts comprometidos via `sou.pp.ua` (`check_ip.php` / `add_ip.php`) e reporta ao atacante por Telegram, além de instalar o Komari Agent como canal de controle remoto.
3. **Malware de monetização** — instala o TraffMonetizer para vender a largura de banda das vítimas.
4. **Scanner massivo** — usa masscan para varrer faixas de IP em busca de SSH aberto (portas 22/5522) e alimenta o ciclo de propagação.

Em resumo: é um **worm de botnet com fins de monetização e controle remoto**, não um simples scanner ou ferramenta de administração.